

3. Définir des mesures de sécurité sur l'écosystème

Acceptabilité du niveau de menace de la partie prenante

NIVEAU DE MENACE	ACCEPTABILITÉ	RECOMMANDATIONS D' ACTIONS
TRÈS ÉLEVÉ – ZONE DE DANGER	Inacceptable	Aucune partie prenante dans cette zone : réduction du risque, ou refus d'établir l'interaction.
ÉLEVÉ – ZONE DE CONTRÔLE	Tolérable sous contrôle	Enrôlement de la partie prenante dans le processus de management du risque : -surveillance particulière, voire accrue, en termes de cyberdéfense ; - audit de sécurité technique et organisationnel ; -réduction/transfert du risque dans le cadre d'un plan d'amélioration continue de la sécurité.
FAIBLE – ZONE DE VEILLE	Acceptable en l'état	Sans objet (menace résiduelle).

3. Définir des mesures de sécurité sur l'écosystème

Comment ?

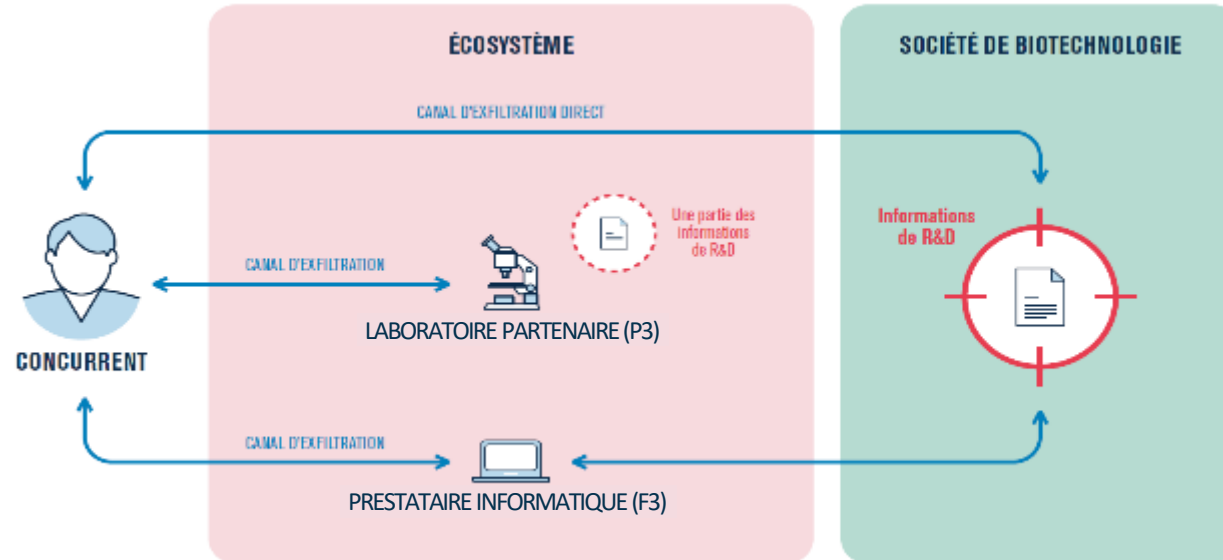
Objectif : recherche de pistes de réduction des risques et traduction en mesures de sécurité

- *Réduire le niveau de menace induit par les parties prenantes critiques (exemple : réduire la dépendance à un sous-traitant)*
- *Agir sur le déroulement des scénarios stratégiques (exemple : rendre la réalisation d'un événement intermédiaire plus difficile pour l'attaquant)*

Les mesures issues de l'atelier 3 seront susceptibles d'impacter la gouvernance de votre organisation, voire celle de vos parties prenantes externes. Par conséquent, des arbitrages du ressort de la direction seront à prévoir.

3. Définir des mesures de sécurité sur l'écosystème

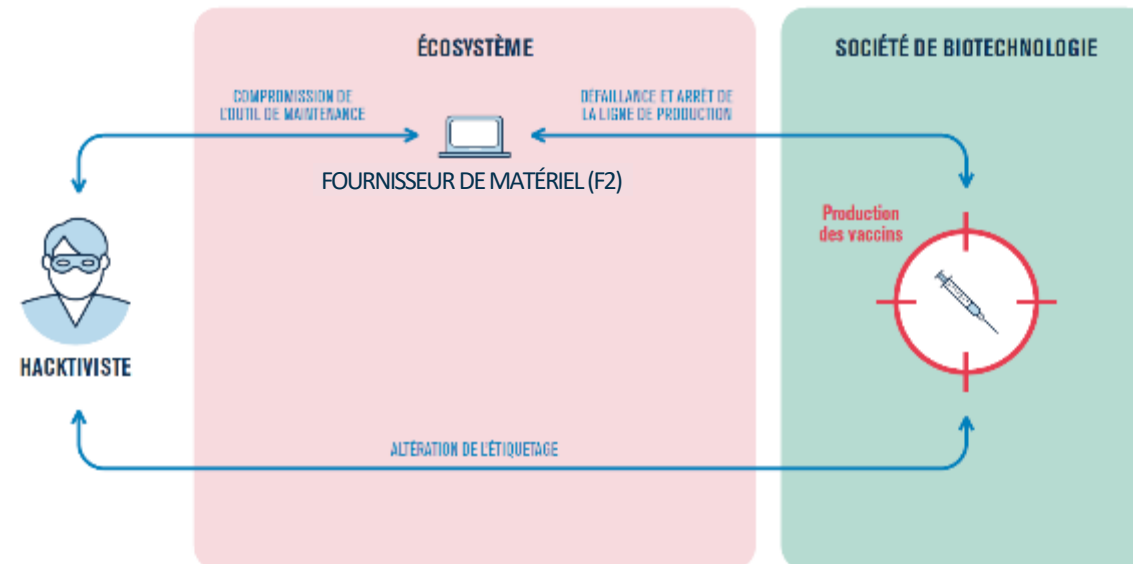
Exemple : société de biotechnologie



Objectif visé : Voler des informations de R&D

Quelles mesures de réduction du risque proposeriez-vous à ce stade de l'étude ?

Objectif visé : Saboter la campagne nationale de vaccination

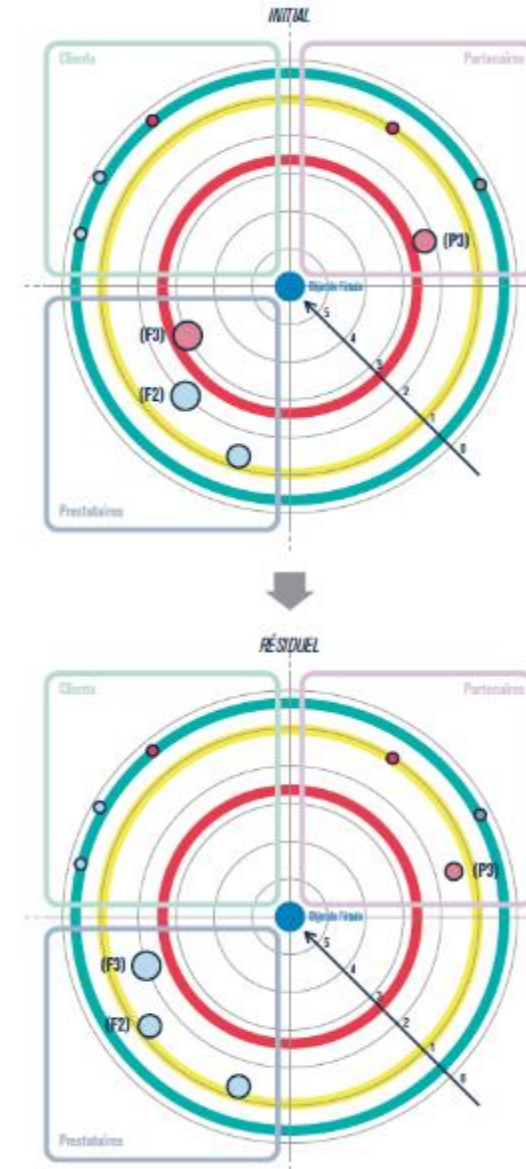


3. Définir des mesures de sécurité sur l'écosystème

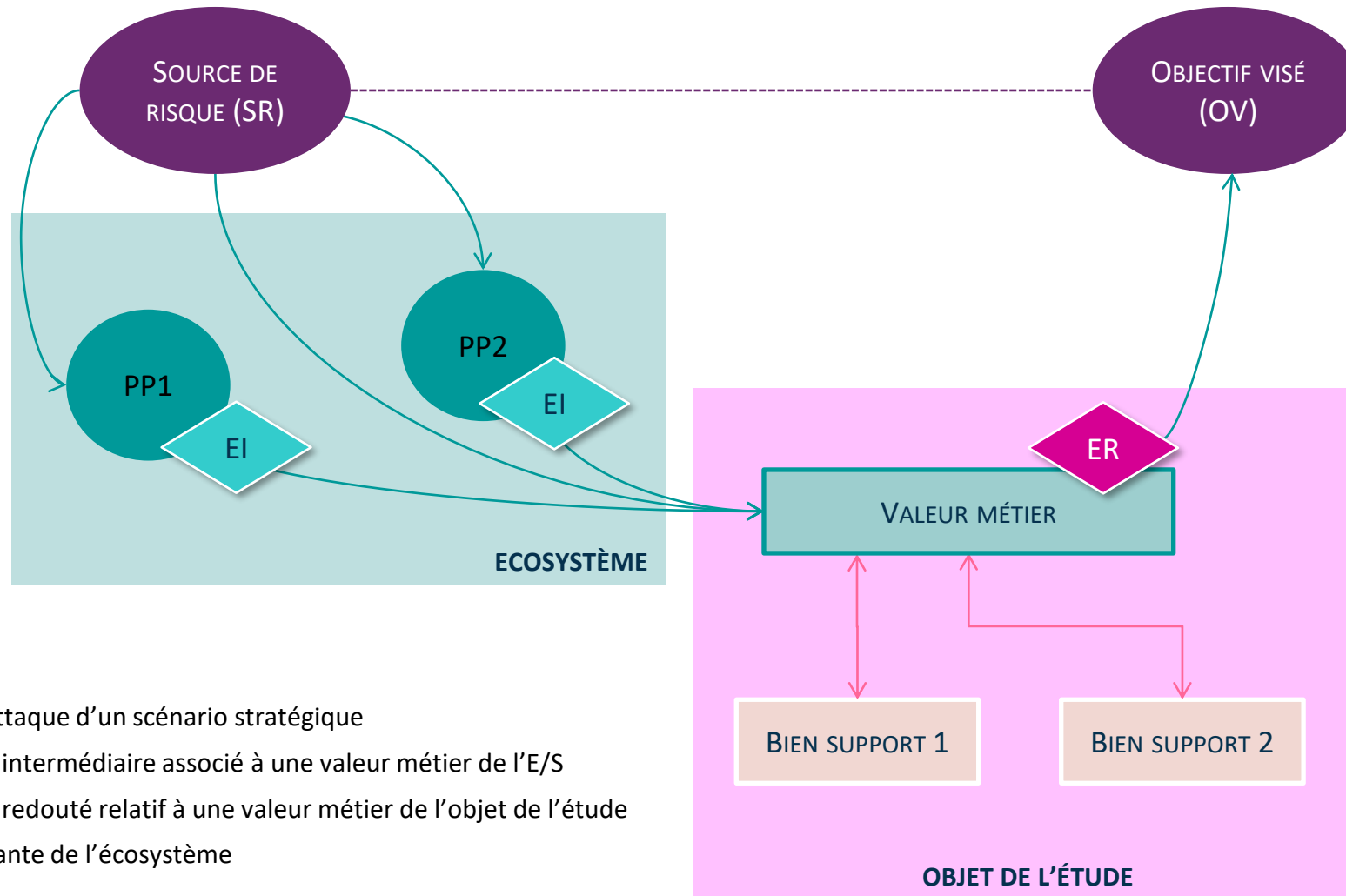
Exemple : société de biotechnologie



PARTIE PRENANTE	CHEMINS D'ATTAQUE STRATÉGIQUES	MESURES DE SÉCURITÉ	MENACE INITIALE	MENACE RESIDUELLE
F2 Fournisseurs de matériel	Arrêt de production par compromission de l'équipement de maintenance	Réduire le risque de piégeage des équipements de maintenance utilisés sur le système industriel. Dotation de matériels de maintenance administrés par la DSI et qui seront mis à disposition du prestataire sur site (permet de réduire la pénétration des fournisseurs de 3 à 2).	2	1,3
F3 Prestataire informatique	Vol d'informations en passant par le prestataire informatique	Accroître la maturité cyber du prestataire (2 → 3): ■ audit de sécurité (à inclure dans le contrat); ■ suivi du plan d'action interne. Renforcer la protection des données de R&D. Solutions à investiguer : chiffrement, cloisonnement du réseau R&D.	3	2
P3 Laboratoires	Vol d'informations sur le système d'information du laboratoire	Diminuer la pénétration des laboratoires (3 → 2): limitation des données transmises au laboratoire au juste besoin (mauvaise habitude actuelle de « tout » diffuser).	2,25	1,5



Récapitulatif (fin de l'atelier 3)



Légende :

- Chemin d'attaque d'un scénario stratégique
- EI Événement intermédiaire associé à une valeur métier de l'E/S
- ER Événement redouté relatif à une valeur métier de l'objet de l'étude
- PP Partie prenante de l'écosystème